

BUILD-SUPABASE.md

ANNEXE C — Catalogue officiel des politiques Row Level Security (RLS)

Version : V1

Statut : Référentiel officiel des politiques RLS de Vitala

1. Objectif

Cette annexe définit les standards de documentation et de gestion des politiques **Row Level Security (RLS)** utilisées dans Vitala.

Elle a pour objectifs de :

- centraliser toutes les politiques RLS ;
- garantir une sécurité homogène ;
- documenter les règles d'accès aux données ;
- faciliter les audits de sécurité ;
- assurer la traçabilité des évolutions.

Toutes les tables métier protégées par RLS doivent être référencées dans ce catalogue.

2. Principes directeurs

Les politiques RLS reposent sur les principes suivants :

- Security by Design
- Zero Trust
- Least Privilege
- Deny by Default
- Documentation obligatoire

Par défaut, aucun accès n'est autorisé tant qu'une politique explicite ne l'accorde.

3. Structure d'une fiche RLS

Chaque politique doit être documentée selon le modèle suivant.

Informations générales

- Nom de la politique
 - Table concernée
 - Domaine fonctionnel
 - Description
 - Responsable technique
-

Opération concernée

Préciser l'opération couverte :

- SELECT
- INSERT
- UPDATE
- DELETE
- ALL

Chaque opération doit être documentée séparément lorsque les règles diffèrent.

Rôles autorisés

Identifier les rôles pouvant utiliser cette politique.

Exemples :

- utilisateur authentifié
 - administrateur
 - service interne
 - Edge Function
 - rôle système
-

Condition d'accès

Décrire précisément :

- les conditions `USING` ;
- les conditions `WITH CHECK` ;
- les contraintes supplémentaires.

Les règles doivent être simples, explicites et vérifiables.

Données protégées

Documenter :

- les colonnes sensibles ;
- les informations personnelles ;
- les données confidentielles.

La justification de la protection doit être indiquée.

Dépendances

Identifier :

- les APIs concernées ;
 - les Domaines concernés ;
 - les Edge Functions ;
 - les vues ;
 - les fonctions SQL.
-

Tests

Chaque politique doit préciser :

- les scénarios autorisés ;
- les scénarios interdits ;
- les résultats attendus.

Les tests doivent être automatisés lorsque cela est possible.

4. Standards des politiques

Les politiques doivent :

- être courtes ;
- être compréhensibles ;
- éviter les conditions complexes ;
- être limitées à une responsabilité unique.

Les politiques très complexes doivent être décomposées.

5. Cas interdits

Les pratiques suivantes sont interdites :

- désactiver RLS sur une table métier ;
- créer des politiques ambiguës ;
- autoriser un accès global sans justification ;
- contourner les contrôles via une fonction SQL.

Toute exception doit être validée par l'architecte.

6. Audit

Chaque politique doit permettre de répondre aux questions suivantes :

- Qui peut accéder aux données ?
- Pourquoi cet accès est-il autorisé ?
- Quelles données sont concernées ?
- Quels risques sont identifiés ?

Cette documentation facilite les audits internes et externes.

7. Maintenance

Toute modification d'une politique RLS doit :

- être réalisée via une migration ;
- être testée ;
- être documentée ;
- être validée avant la mise en production.

Les anciennes politiques doivent rester traçables.

8. Références croisées

Chaque politique doit être reliée à :

- la table concernée ;
 - le Domain Model ;
 - les API Contracts ;
 - BUILD-SECURITY ;
 - BUILD-SUPABASE ;
 - les migrations associées.
-

9. Critères de conformité

Une politique RLS est conforme lorsqu'elle :

- respecte le principe du moindre privilège ;
 - est documentée ;
 - est testée ;
 - protège correctement les données concernées ;
 - est enregistrée dans ce catalogue.
-

10. Évolution du catalogue

Le catalogue des politiques RLS est un document vivant.

Toute création, modification ou suppression d'une politique doit être immédiatement répercutée dans cette annexe.

11. Conclusion

Le Catalogue officiel des politiques RLS constitue le référentiel de sécurité de PostgreSQL dans Vitala.

Il garantit une gestion cohérente, documentée et évolutive des droits d'accès aux données, en assurant que chaque politique respecte les exigences de sécurité, de confidentialité et de conformité définies par l'architecture de la plateforme.